Vulnerability Assessment.

CONFIDENTIAL (SAMPLE)

CLIENT	PERFORMED BY	ISSUED
Example Client (fictional)	DODO, through the ARES platform	2026-03-12

VERSION	STATUS
1.0	Complete

SAMPLE REPORT. FICTIONAL TARGET.

The structure and the types of finding come from a real ARES output. Every name, address, hostname, serial number and identifier has been replaced or redacted. Addresses are from the reserved documentation range 10.0.2.0/24.

// TABLE OF CONTENTS

01 Document Information 01

02 Executive Summary 02
- 2.1 OVERVIEW
- 2.2 HIGH-LEVEL FINDINGS
- 2.3 FINDING STATUS

03 Scope and Rules of Engagement 03

04 Method and Limitations 04
- 4.1 METHOD
- 4.2 LIMITATIONS

05 Findings 05
- F-01 TO F-07

06 Remediation Plan 06

07 Informational Observations 07

01 Document Information

DOCUMENT TITLE	Vulnerability Assessment: Finance VLAN	DOCUMENT ID	DEMO-VA-0001
CLIENT	Example Client (fictional)	PERFORMED BY	DODO, through the ARES platform
ISSUED	2026-03-12 · Version 1.0 · Status: Complete	CLASSIFICATION	Confidential (sample)
TARGET	10.0.2.0/24 (Finance VLAN)	TEST WINDOW	2026-03-12, 09:00–15:30 UTC

AI-GENERATED CONTENT

ARES is an AI system and can make mistakes: always verify the results. Every finding, severity level and remediation suggestion must be reviewed and validated by a qualified security professional before any action is taken.

02 Executive Summary

// 2.1 Overview

ARES ran a vulnerability assessment on the Finance VLAN of a fictional organization (`10.0.2.0/24`) using ARES. We found 19 live hosts, all infrastructure: network switches, server management controllers, virtualization, backup and storage. No user workstations were found.

The main risk on this VLAN is unsupported or outdated firmware and software on core infrastructure. Several devices run versions the vendor no longer maintains, or versions affected by vulnerabilities the vendor itself rates as critical. Some of these can be exploited remotely without credentials, according to vendor advisories. Nothing was exploited during this assessment.

Most critical and high findings are resolved by updating firmware or software, or by replacing end-of-life devices. Restricting Finance interfaces to a dedicated administration network would reduce exposure while updates are planned.

// 2.2 High-Level Findings

CRITICAL	HIGH	MEDIUM
2	3	2

// 2.3 Finding Status

Each finding carries one of two statuses:

- **Confirmed:** the condition was observed directly, or the identified product and version are documented by the vendor as vulnerable.
- **Potential, verification advised:** the exact version or configuration could not be determined remotely, so the finding needs a quick authenticated check, for example reading the firmware version from the device console.

03 Scope and Rules of Engagement

- **In scope:** `10.0.2.0/24` (Finance VLAN), including the gateway `10.0.2.254`.
- **Out of scope:** all other internal ranges and all hosts on the Internet. No out-of-scope address was contacted.
- **Environment:** production.
- **Constraints:** no exploitation, no credential brute force, no denial-of-service or destructive tests. Only light, rate-limited scans on the gateway and the DNS server. Credential testing was limited to the vendor default SNMP community `public`.

04 Method and Limitations

// 4.1

Method

Low-rate TCP connect discovery across the /24. Service and version enumeration on every live host. Fingerprinting through HTTP(S) responses, TLS certificates, DNS queries and default SNMP checks. Observed products and versions were mapped against the NVD, CISA's Known Exploited Vulnerabilities catalog and vendor security advisories. Validation was non-destructive only: banner and version comparison, read-only requests, safe configuration checks.

// 4.2

Limitations

- Discovery used unprivileged TCP connect probes. A host with none of the probed ports open might not have been detected.
- No credentials were used. Versions were read from network-visible banners, and several devices do not expose their firmware version remotely. These findings are marked Potential.
- Not tested: application-level tests, authenticated tests, and logins with any credentials that might be found.

05 Findings

ID	FINDING	STATUS	SEVERITY
F-01	Core switch firmware is past the vendor's end of maintenance	Confirmed (version)	CRITICAL
F-02	End-of-life switch with unauthenticated remote code execution in the web interface, no fix available	Confirmed (product)	CRITICAL
F-03	regreSSHion (CVE-2024-6387) affects the core switch SSH service	Confirmed	HIGH
F-04	Virtualization management server is past end of general support	Confirmed (version)	HIGH
F-05	Server management controller firmware appears to date from 2019	Potential	HIGH
F-06	SNMPv2c answers to the default community `public`	Confirmed	MEDIUM
F-07	Default web dashboard and PHP diagnostic page exposed without authentication	Confirmed	MEDIUM

Finding ID: F-01

CRITICAL

TITLE **Core switch firmware is past the vendor's end of maintenance**

HOST AFFECTED: 10.0.2.254:443 · **STATUS:** Confirmed (version). Exposure follows the vendor's policy.

ADVISORY / CVSS

vendor advisories · CVSS 9.8

DESCRIPTION

The core switch, which is also the default gateway, runs a firmware branch that is past the vendor's end of maintenance and no longer receives security fixes. The vendor's advisories state that releases beyond end of maintenance are presumed affected, including unauthenticated flaws in the web management interface and in system daemons. The HTTPS management interface is reachable from the VLAN. Compromising this device would expose all routed traffic, and a single firmware update fixes the finding on every VLAN it serves.

EVIDENCE

- SNMP system description with model and firmware version [REDACTED]
- TLS certificate subject [REDACTED]

- Switch web interface served on port 443

REMEDIATION

Upgrade to a supported release at or above the vendor's fixed level. Check the release notes for the supported upgrade path, which may need an intermediate step. Until then, restrict SSH, HTTPS and REST access to a dedicated management VLAN or a control-plane ACL.

Finding ID: F-02 CRITICAL

TITLE **End-of-life switch with unauthenticated remote code execution in the web interface**

HOST AFFECTED: 10.0.2.248:443 · STATUS: Confirmed (product). Confirm the exact model.

ADVISORY / CVSS

vendor advisory · CVSS 9.8

DESCRIPTION

The device is a small-business switch from a product line that has reached end of life. The vendor's advisory describes several flaws in its web interface that allow an unauthenticated remote attacker to run code as root. The vendor states that it has not released and will not release fixes, and that no workaround exists. Telnet is also enabled on this device.

EVIDENCE

- Telnet fingerprint identifying the product family
- Web interface with the session-prefixed URL structure typical of this vendor's small-business line

REMEDIATION

Replace the switch with a supported model. Meanwhile, allow ports 80/443 and Telnet only from a single management host. Confirm the exact model with `show version`.

Finding ID: F-03 HIGH

TITLE **regreSSHion (CVE-2024-6387) affects the core switch SSH service**

HOST AFFECTED: 10.0.2.254:22 · STATUS: Confirmed

ADVISORY / CVSS

vendor advisory, CVE-2024-6387 · CVSS 8.1

DESCRIPTION

The vendor confirms that this firmware branch is affected by CVE-2024-6387, a race condition in the OpenSSH server that can lead to remote code execution without authentication. This branch has no fix.

EVIDENCE

- SSH banner [REDACTED]

REMEDIATION

Resolved by the upgrade in F-01. Meanwhile, restrict SSH to management hosts.

Finding ID: F-04 HIGH

TITLE **Virtualization management server is past end of general support**

HOST AFFECTED: 10.0.2.10:443 · **STATUS:** Confirmed (version and end of life). Individual CVEs depend on the update level.

ADVISORY / CVSS

several CVEs · CVSS up to 9.8

DESCRIPTION

The management server runs a version that left general support in 2022. Depending on the update level, several unauthenticated remote code execution vulnerabilities apply to it, and most of them appear in CISA's Known Exploited Vulnerabilities catalog. Management services and SSH are reachable from the VLAN.

EVIDENCE

- The directory service reports the platform version [REDACTED]
- Client login page served on port 443

REMEDIATION

Migrate to a supported major version. Meanwhile, apply the last update available for the branch, restrict access to administrator hosts, and disable SSH on the appliance when it is not needed.

Finding ID: F-05

HIGH

TITLE **Server management controller firmware appears to date from 2019**

HOST AFFECTED: 10.0.2.20:443 · STATUS: Potential, verification advised

ADVISORY / CVSS

vendor advisory · CVSS 9.8 (unauthenticated remote code execution), if the version is confirmed

DESCRIPTION

Files of the controller's web interface carry a build date in 2019, which suggests a firmware older than the release the vendor lists as fixed for an unauthenticated remote code execution flaw. The SNMP uptime is over a year, so the controller has not been restarted or updated for a long time. The controller gives out-of-band control of the server, including console and virtual media, and its interface is reachable from the VLAN.

WHAT WE COULD NOT DETERMINE

> The exact firmware version.

EVIDENCE

- SNMP system name and uptime
- A web interface file with a `Last-Modified` date in 2019

REMEDIATION

Read the version from the device console and update to the latest firmware for the platform. Restrict access to a management network through the controller's IP filter.

Finding ID: F-06

MEDIUM

TITLE **SNMPv2c answers to the default community `public`**

HOST AFFECTED: 10.0.2.254, 10.0.2.20 · port 161 · STATUS: Confirmed

DESCRIPTION

The core switch and the management controller answer SNMPv2c requests with the default community `public`. Anyone on the VLAN can read device identity and software version, and usually the full MIB. Only identity objects were queried during the assessment. SNMPv2c also sends the community string in clear text.

EVIDENCE

- System description from the core switch, firmware version [REDACTED]
- System name and uptime from the management controller

REMEDIATION

Remove the public community. Use SNMPv3 with authentication and encryption, limited to the monitoring server.

Finding ID: F-07 MEDIUM

TITLE **Default web dashboard and PHP diagnostic page exposed without authentication**

HOST AFFECTED: 10.0.2.30:443 · STATUS: Confirmed

DESCRIPTION

The default dashboard of the web server package is published over HTTPS, and the PHP diagnostic page returns the full PHP configuration without authentication. It reveals filesystem paths, loaded modules, environment variables and configuration settings that help an attacker target the server.

EVIDENCE

- GET /dashboard/ returned the diagnostic page (response saved, values redacted)

REMEDIATION

Remove the default dashboard directory and any diagnostic page from the web root, or restrict access to localhost.

06 Remediation Plan

#	FINDING(S)	ACTION	PRIORITY
01	F-01, F-02, F-03	Upgrade the core switch firmware to a supported release, and replace the end-of-life switch. Meanwhile, restrict web, SSH and Telnet to a single management host.	PRIORITY 1
02	F-01 to F-07	Restrict all management interfaces (switches, controllers, virtualization, storage) to a dedicated administration network or a jump host.	PRIORITY 1
03	F-04, F-05, F-06	Migrate the virtualization management server to a supported version. Update the management controller firmware. Replace the default SNMP community with SNMPv3.	PRIORITY 2
04	F-07	Remove the default dashboard and diagnostic page from the web server.	PRIORITY 3

07 Informational Observations

// 7.1

Positive

- DNS zone transfers (AXFR) are refused.
- Anonymous FTP login is rejected on the storage appliance.
- Management web interfaces redirect to their login pages, and API endpoints require authentication.

// 7.2

Omitted from this sample

The host inventory, the lower-severity findings and per-host service notes appear in full reports.

Report generated by ARES for DODO, 2026-03-12. Confidential: restricted distribution (sample).
Licensed under CC BY-ND 4.0. The ARES software, name and logo remain the property of DODO.